

Millie

Title: Security Incident Management Policy	Policy #: IT-009
Effective Date: Jul 5, 2022	Last Revised: May 2, 2022

I. Scope

This Policy applies to all facilities and locations owned, operated, or managed by Millie, Inc. (“Company”), and all Company personnel. For purposes of this Policy, the term “personnel” includes all licensed professionals and staff who perform services on behalf of Company.

II. Policy

a. It is Company’s policy to ensure the prompt reporting of and response to security incidents in order to prevent the occurrence of similar incidents in the future and safeguard Company’s PHI.

b. This Policy governs the reporting, investigation and management of actual and suspected security incidents that may compromise the security of PHI or cause the loss of or damage to Company property.

III. Procedure

a. Incident Reporting.

i. Subject to the considerations described below, all personnel shall be required to promptly report to the Chief Security Officer, or his or her designee, any observed or suspected (i) security weaknesses or threats to the IT System, (ii) violations of Company’s security policies, and (iii) events that could compromise the integrity, confidentiality and availability of PHI. If the security incident could be considered a Breach of HIPAA, the Chief Security Officer shall immediately notify the Chief Privacy Officer. Provided below is a non-exhaustive list of incidents that are to be reported to the Chief Security Officer or his or her designee:

- Actual or suspected loss or unauthorized disclosure of PHI;
- Unauthorized access to or modification of PHI;
- Unusual behavior of the IT System (e.g., missing files, frequent crashes, misrouted messages);

- Unauthorized use of the IT System;
- Loss, theft or disclosure of a password or other access control mechanism; or
- Theft or loss of or material damage to Company property.

ii. The following events may indicate a security threat to the IT System and are to be reported to the Chief Security Officer:

- Inability to log on to the IT System or any denial of service to a Company account; or
- Threatened or actual introduction of a virus.

iii. Any personnel member who is uncertain as to whether a particular event is reportable should contact his or her supervisor. The Chief Security Officer shall investigate all reports within 24 hours of receipt.

b. *Incident Response.*

i. The Chief Security Officer, in conjunction with the Chief Compliance Officer and Chief Privacy Officer, as appropriate, shall be responsible for managing Company's response to all reported security incidents. Upon learning of a security incident, the Chief Security Officer shall conduct a preliminary investigation within 24 hours of the reported incident for purposes of ascertaining whether a bona fide security event has occurred. If a security incident is verified, the Chief Security Officer shall promptly determine the nature and scope of the incident and shall promptly report the matter to the Chief Privacy Officer and Chief Compliance Officer, who shall report the incident to the Chief Executive Officer and others as appropriate and required. The Chief Security Officer shall then designate any other personnel, third parties and other resources he or she deems necessary to effectively respond to the specific incident and obtain any necessary approvals from the Chief Compliance Officer or Chief Executive Officer.

ii. Regardless of the nature and scope of the incident, Company's response shall be based upon the following order of priorities, as applicable:

- Protection of human life and safety;
- Protection of PHI against unauthorized disclosure, destruction or modification;
- Prevention or mitigation of damage to Company's assets;
- Notification of any third parties that may be adversely affected by the event; however, notification shall not be made unless and until approved by the General Counsel;

- Minimizing disruption of Company's computing resources and processes; and
- Reporting the incident to applicable law enforcement agencies and insurance carriers, however, notification shall not be made unless and until approved by the Chief Legal Officer.

iii. Personnel shall not discuss any events pertaining to specific security incidents with other individuals (including other personnel), except as permitted under this Policy. In no event shall personnel attempt to resolve a suspected security incident without the authorization of the Chief Security Officer and Chief Compliance Officer. All personnel shall cooperate with the Chief Security Officer and Chief Compliance Officer with respect to all aspects of the incident response process.

c. Log.

i. The Chief Security Officer shall be responsible for maintaining a log containing a written record of all reported incidents and the details and events relating to the response process, including, as applicable:

- The type of incident;
- The date of the incident;
- The date the incident was reported to the Chief Security Officer;
- If applicable, the date the incident was reported to Company by its Business Associate;
- The manner in which the incident was identified;
- All internal and external discussions (including the parties and the dates, times and content of same), unless such discussions are privileged in which case, the content shall not be included;
- Copies of security audit logs and records;
- All remedial actions implemented, the dates of implementation and the results thereof, such as reinstallation of Company's operating system;
- Any actions taken to contain the impact of the incident (e.g., third-party notifications, including an accounting of the disclosure of PHI in accordance with Company's Policy on Accounting of Disclosures of PHI);
- Any law enforcement agencies notified and the dates of such notifications;

- All correspondence with insurance carriers; and
- Date the incident was closed.

d. Post-Incident Analysis.

i. After an incident has been satisfactorily resolved or contained, the Chief Security Officer shall prepare a written report for submission to the Chief Privacy Officer and Chief Compliance Officer, which shall include the following information, as applicable:

- A detailed description of the incident;
- The manner in which the incident occurred;
- The vulnerabilities in Company's security protocols and/or the operation of the IT System that were exploited (e.g., how unauthorized access was gained and other relevant details);
- The manner in which the incident was resolved or contained;
- Whether existing security policies were adequate or require updating;
- Any unresolved vulnerabilities;
- An inventory update for purposes of determining the extent of loss or damage to property of Company; and
- Any law enforcement agencies notified.

ii. The Chief Compliance Officer and Chief Privacy Officer shall forward such report to the Chief Executive Officer, as appropriate.

e. Annual Report.

i. The Chief Security Officer and the Chief Privacy Officer will endeavor to prepare an annual privacy and security report for submission to the Chief Executive Officer, which shall include the following items:

- All incidents reported and responded to during the prior year, including breaches;
- Security vulnerabilities that were corrected;
- The costs associated with each security incident;
- Identification of any existing security weaknesses; and

- Recommendations to improve Company's security defenses and limit the frequency, damage and cost of future occurrences.

IV. References

- 45 C.F.R. § 164.308(a)(6)